

Security Incident Report

Unauthorized Remote Access Through Vulnerable PHP Web Application

Section 1: Identify the Attack Technique

The attack technique involved Remote Code Execution (RCE) through an insecure PHP upload directory. During the assessment, a PHP Meterpreter reverse shell payload was uploaded and executed through a vulnerable web application hosted on a local PHP server. Once executed, the payload established an outbound reverse TCP connection to the attacker's Metasploit listener, providing remote command execution capabilities.

The attack leveraged the following techniques:

- Initial Access through vulnerable web application
- Execution of malicious PHP payload
- Command and Script Interpreter abuse
- Remote Access Software functionality through Meterpreter
- System Discovery and Enumeration

The successful exploitation resulted in unauthorized shell access to the target environment and allowed post-exploitation activities to be performed.

Section 2: Document the Incident

A simulated internal security assessment was conducted after suspicious activity was observed on a web application hosted within the organization's internal network. The objective of the assessment was to identify potential vulnerabilities and determine whether an attacker could gain unauthorized access to internal resources.

The cybersecurity analyst prepared a controlled testing environment using Kali Linux and deployed simulated user accounts and internal services. During the assessment, a vulnerable PHP upload directory was identified that allowed arbitrary PHP files to be executed by the web server.

The analyst performed reconnaissance using Nmap to enumerate exposed services on the target host. The scan identified three active services:

- SSH service on port 22
- PHP web server on port 8080
- Internal TCP Echo service on port 9003

Following reconnaissance, the analyst generated a Meterpreter reverse shell payload using msfvenom and deployed the payload to the vulnerable upload directory. A Metasploit multi-handler listener was configured to receive inbound connections.

After triggering the malicious PHP payload through the web application, a Meterpreter session was successfully established. The analyst verified access by executing system enumeration commands, identifying the current user context, and retrieving a simulated sensitive file named flag.txt.

Further post-exploitation activities confirmed that the attacker had the ability to:

- Execute operating system commands
- Enumerate users and system information
- Browse files and directories
- Access sensitive information stored on the host

The assessment concluded that the root cause of the compromise was insecure file upload functionality combined with unrestricted execution permissions within the upload directory. These weaknesses enabled arbitrary code execution and unauthorized system access.

Section 3: Security Findings

Finding 1 – Remote Code Execution via PHP Upload Directory

Severity: Critical

The web application permitted arbitrary PHP files to be uploaded and executed. This allowed an attacker to deploy a Meterpreter payload and obtain remote shell access.

Evidence:

- Successful Meterpreter session established
- Remote command execution achieved
- Access to sensitive files confirmed

Impact:

- Complete system compromise
- Unauthorized access to application resources
- Potential credential theft
- Potential lateral movement

Risk Rating: Critical

Finding 2 – Exposed Internal TCP Service

Severity: Medium

An internal Echo TCP service was accessible on port 9003 and accepted arbitrary user input.

Evidence:

- Successful connection using Netcat
- Service responded to arbitrary user commands

Impact:

- Service fingerprinting
- Internal reconnaissance
- Potential attack surface expansion

Risk Rating: Medium

Section 4: Root Cause Analysis

The primary cause of the incident was insecure application configuration.

The web application failed to restrict executable content within the upload directory and did not validate uploaded file types. As a result, malicious PHP code was uploaded and executed by the server.

Additionally, internal services were exposed without sufficient access controls, increasing the attack surface available to potential attackers.

Section 5: MITRE ATT&CK Mapping

Tactic	Technique	ID
Initial Access	Exploit Public-Facing Application	T1190
Execution	Command and Scripting Interpreter	T1059
Persistence	Web Shell	T1505.003
Discovery	System Information Discovery	T1082
Discovery	File and Directory Discovery	T1083
Command and Control	Application Layer Protocol	T1071

Section 6: Remediation Recommendations

The security team recommends implementing the following controls:

Web Application Security

- Disable PHP execution inside upload directories
- Restrict file upload types
- Validate uploaded content
- Implement secure coding practices
- Deploy Web Application Firewall (WAF)

Infrastructure Security

- Remove unnecessary internal services
- Restrict network access using firewall rules
- Implement network segmentation
- Apply least-privilege permissions

Monitoring and Detection

- Monitor suspicious file uploads
 - Detect outbound reverse shell connections
 - Monitor command execution events
 - Enable centralized logging and alerting
-

Section 7: Conclusion

The assessment demonstrated how insecure file upload functionality can lead to complete system compromise. Through reconnaissance, exploitation, and post-exploitation activities, the cybersecurity analyst successfully obtained unauthorized access to the target environment and validated multiple security weaknesses.

The findings highlight the importance of secure application development, access controls, and continuous monitoring to prevent similar attacks in production environments.

Overall Risk Rating: Critical

Incident Status: Contained

Assessment Outcome: Successful Validation of Security Weaknesses